

Lecture 8

Processes and Host Security

CoSc2043 – Network and System Administration

Lecture Overview

- ◆ UNIX Processes

- ◆ Running
programs

- ◆ Monitoring
processes

- ◆ Killing processes.

- ◆ Why Security?

- ◆ System Security Issues

- ◆ Network Security Issues

- ◆ Physical and Session
Security Issues

- ◆ Security Implementation

Programs & Processes

- ◆ Program – file which can be run
 - Binary executables
 - Shell scripts
- ◆ Process – A running program
 - Loaded in physical memory
 - Stored in virtual memory (swap)

Virtual Memory

- ◆ Extends amount of physical memory

- ◆ UNIX

- Size of swap = amount of usable memory
- Physical memory (RAM) mirrored in swap

- ◆ Linux: $\text{Memory} = \text{swap} + \text{RAM}$

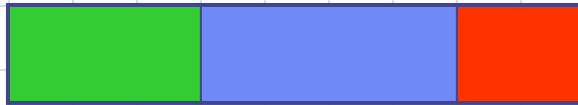
- ◆ Swapping

- Moving pages to and from memory
- Page – block (unit) of RAM

Swap Allocation

BSD UNIX:

RAM:

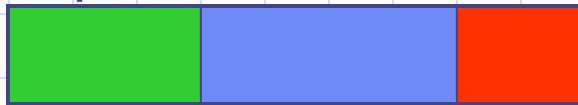


Swap:



AT&T SVR4/Linux:

RAM:



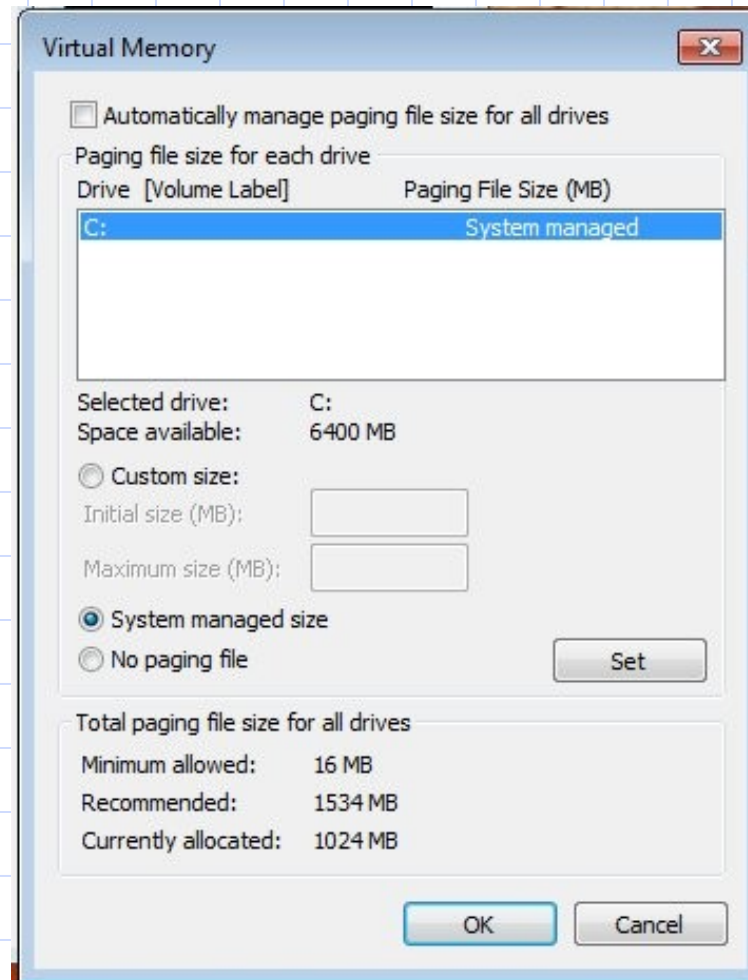
Swap:



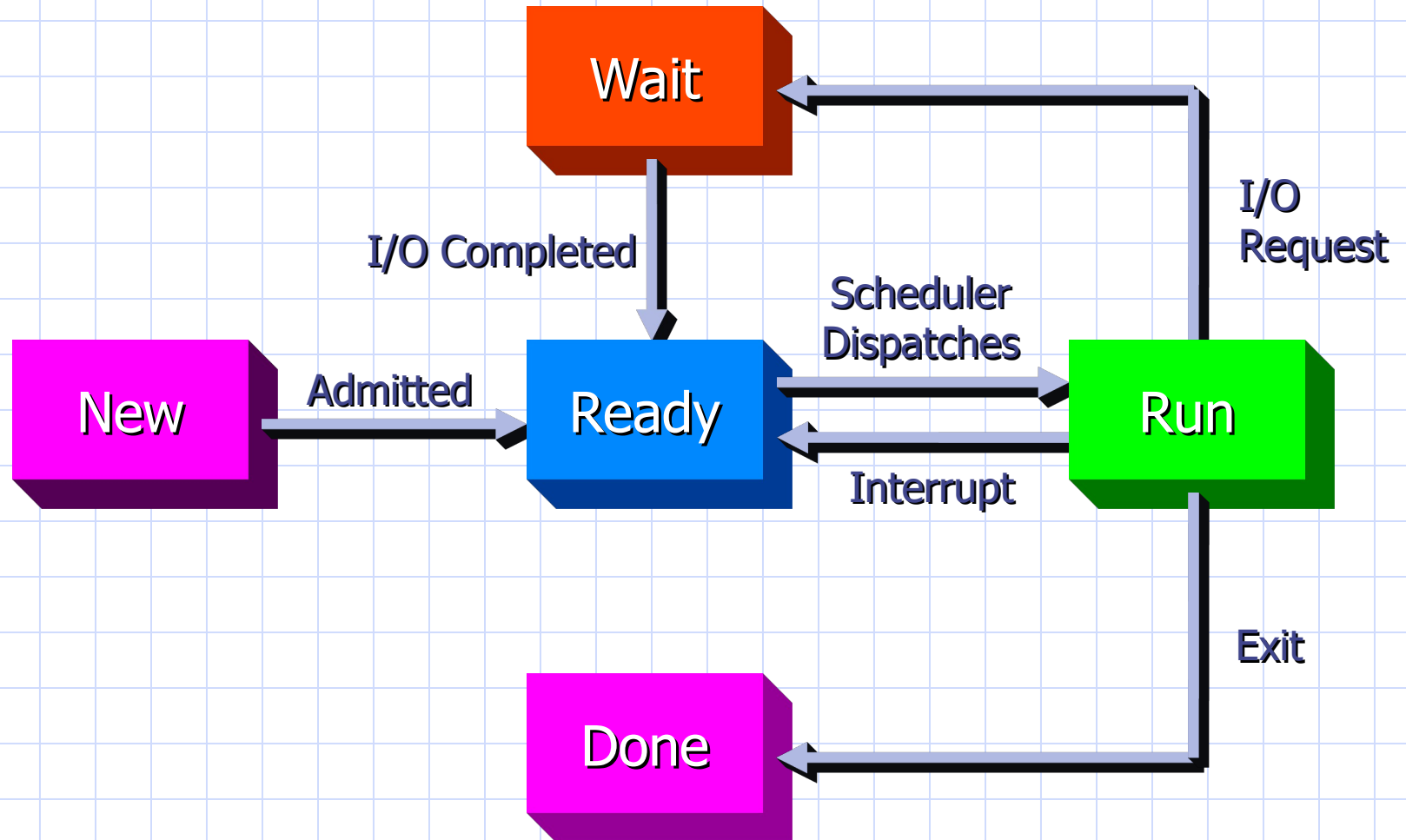
Windows: `C:\pagefile.sys` (Grows as needed)

Which works better when?

Windows pagefile.sys Settings



Process Lifecycle



Process Components



Address space map

Status



Owner

Blocked signals

Priority

Resources used

■ Running

■ Runnable

■ Sleeping

■ Stopped

■ Zombie

Process Ownership

- ◆ Real User (User starting the process)
 - UID: User ID Number
 - GID: Group ID Number
- ◆ Effective User (Permissions for process)
 - EUID: Effective User ID Number
 - EGID: Effective Group ID Number

Process Lifecycle

- ◆ Parent process “forks” a child
- ◆ Process identifiers
 - PID: Process ID Number
 - PPID: Parent Process ID Number
- ◆ Child finishes
 - Sends status message to parent
 - Zombie – waits for parent acknowledgment
 - Orphan – `init` (PID 1) becomes parent

Running a command

- ◆ Type in the command name
- ◆ Shell searched for the command
- ◆ If found, shell “forks” the command
- ◆ How is the command found?
 - PATH environment variable
 - `which` – Displays full path to command
 - Beware of “.” in your PATH

Background Jobs

◆ Foreground process

- Returns control to shell after it finished
- Most common usage

◆ Background process

- Returns control to shell immediately
- "&" typed after command name
- Runs concurrently



Daemons

- ◆ Special programs which performs a some task without intervention
- ◆ Started in the background
(often at system startup)
- ◆ Name of most ends in 'd'

"Daemon" is actually a much older form of "demon"; daemons have no particular bias towards good or evil, but rather serve to help define a person's character or personality.

~*Evi Nemeth*

fg, bg, & jobs

- ◆ Can switch between modes
- ◆ Send signal to stop a process
- ◆ Commands
 - fg – Run process in foreground
 - bg – Run process in background
 - jobs – List shell child processes

Signals

- ◆ Used to communicate with processes
- ◆ Terminal signals
 - `<Ctrl><c>` - Terminate process
 - `<Ctrl><z>` - Stop (suspend) process
- ◆ `kill [-signal] pid`
 - Sends signal to process PID
 - Default is to terminate the process

Common Signals

#	Name	Description
1	HUP	Hangup
2	INT	Interrupt
3	QUIT	Quit
9	KILL	KILL
15	TERM	Software Termination
	STOP	Stop

Process Priority

- ◆ How much CPU time granted relative to other processes
- ◆ **nice** – Sets the priority value at start
- ◆ **renice** – Changes priority
- ◆ Ranges

System	Range
Solaris	0 to 39
RedHat	-20 to 20

System Load

- ◆ Average number of “Runnable” processes
- ◆ Measure of how busy the system is
- ◆ Performance deteriorates at loads of 6+
- ◆ Good for creating a baseline
- ◆ `uptime` – Load average
(5, 10, 15 minutes)

Monitoring Processes (Linux)

◆ ps

- BSD – Sorts by %CPU Usage
- SVR4 – Sorts by PID

◆ top

- Full terminal screen display
- Sortable
- Can kill and renice processes

Information from `ps`

- ◆ **PID**
- ◆ **USER**
- ◆ **PRI/NI** - Priority/Nice level
- ◆ **RSS/SIZE** - Resident/Total Memory used
- ◆ **STAT** - Process State
- ◆ **%CPU/%MEM** - % of System CPU/Memory
- ◆ **TIME** - CPU time used
- ◆ **Command**

/proc Filesystem

- ◆ Pseudo filesystem
- ◆ Interface to memory-related kernel data structures
- ◆ Each PID has it's own directory
 - `cwd` – Symlink to current working directory
 - `exe` – Symlink to program
 - `cmdline` – command line options
 - `environ` – command line environment
 - `stat` – process status

Monitoring Processes (Windows)

◆ Task Manager

- Graphical viewer
- Can also sort or kill processes

◆ **tasklist**

- Command line Viewer
- Can view associated dll files

◆ **wmic process [options]**

- Can view, start, and kill processes
- Remote connection capabilities

SysInternals - Process Tools

◆ Command Line tools

- Pslist – display running processes
- Pskill – Kill processes by name or PID
- Psexec – Run programs remotely

◆ GUI Tools

- Procmon – Detailed process info
- RAMMap – View RAM usage
- VMMap – View Virtual Memory usage

Runaway Processes

- ◆ Can eat up your resources
- ◆ Lists users and PIDs accessing a resource
 - **fuser**
 - **lsof**
- ◆ Kill the process and clean up

Elevating Access

◆ Principle of Least Privilege

◆ `su [-] <user>` - "Switch user"

- Requires user password if not run as root
- `'-'` runs a subshell owned by user

◆ Microsoft `runas` (Automatic Popup Win7)

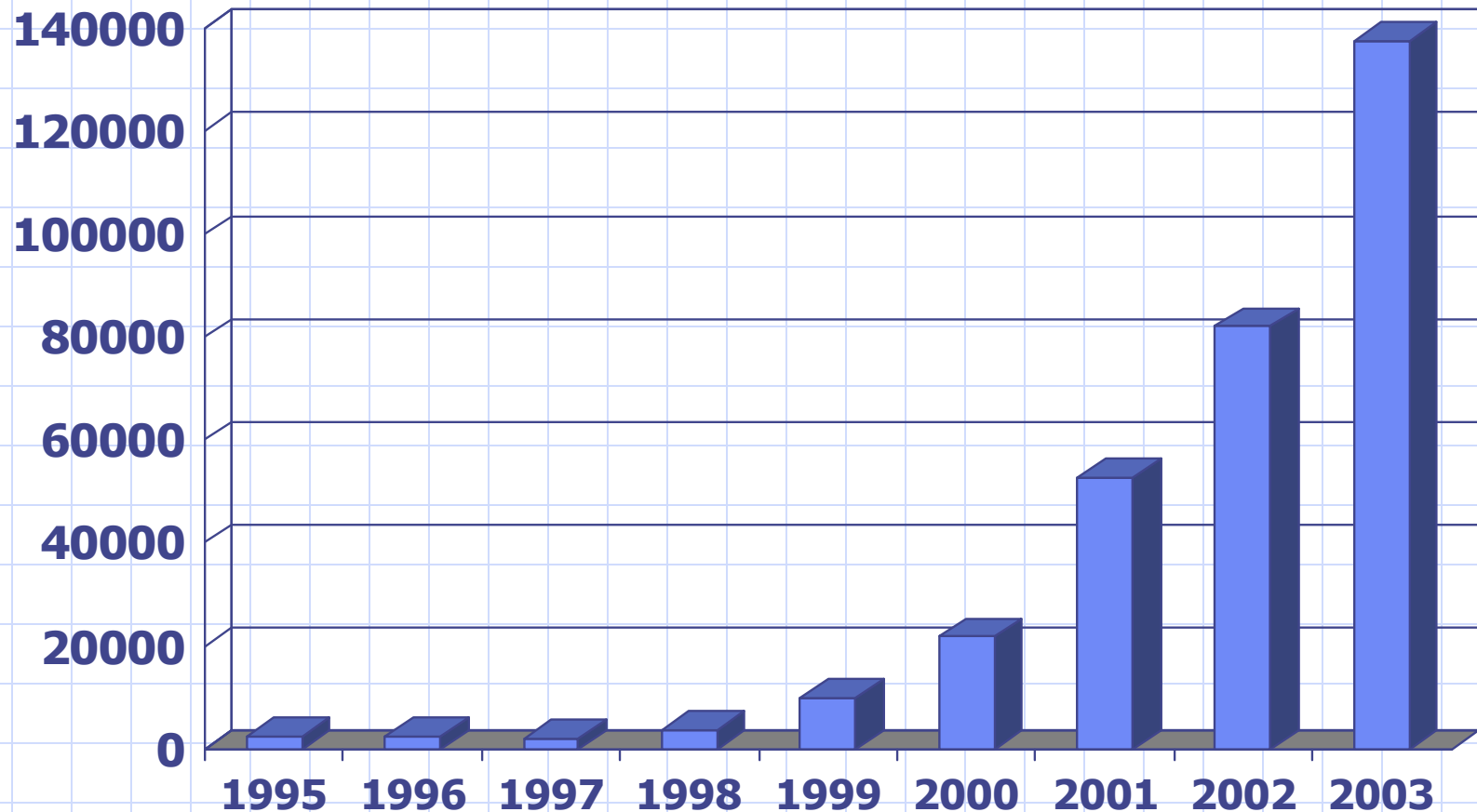
◆ Sudo – Run programs as superuser

- `/etc/sudoers` – who can run what
- `visudo` – Editor for `/etc/sudoers`
- `sudo` – Used to run commands as root
- Windows version available

Why Worry about Security?

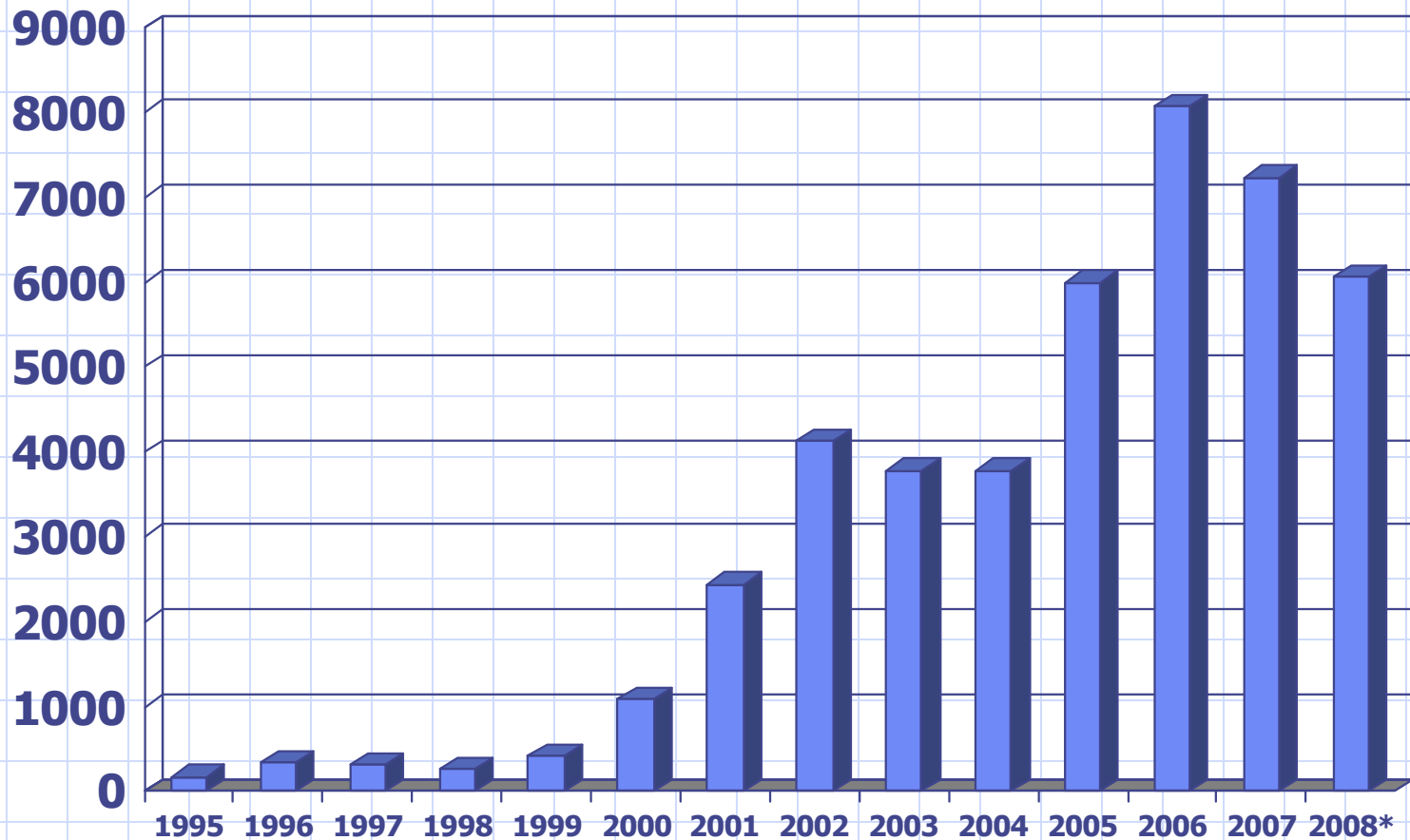
- ◆ Y2K Bug – 1/1/2000
- ◆ DDoS Attack of Yahoo, CNN – 2/2000
- ◆ Microsoft break-in – 10/2000
- ◆ SPAM and Phishing
- ◆ Viruses and Worms
 - Internet Worm – 11/1988
 - Melissa/ILoveYou Viruses – 1999 - 2000
 - CodeRed/Nimda/Slammer/Sobig – 2001-2003
 - MyDoom, Netsky/Bagel – 2004
 - Stuxnet - 2010
 - SPAM/Virus Writer Connection
- ◆ Terrorist Attacks/Katrina
- ◆ Numerous Web Defacements
- ◆ Mobile Computing?

Reported Incidents



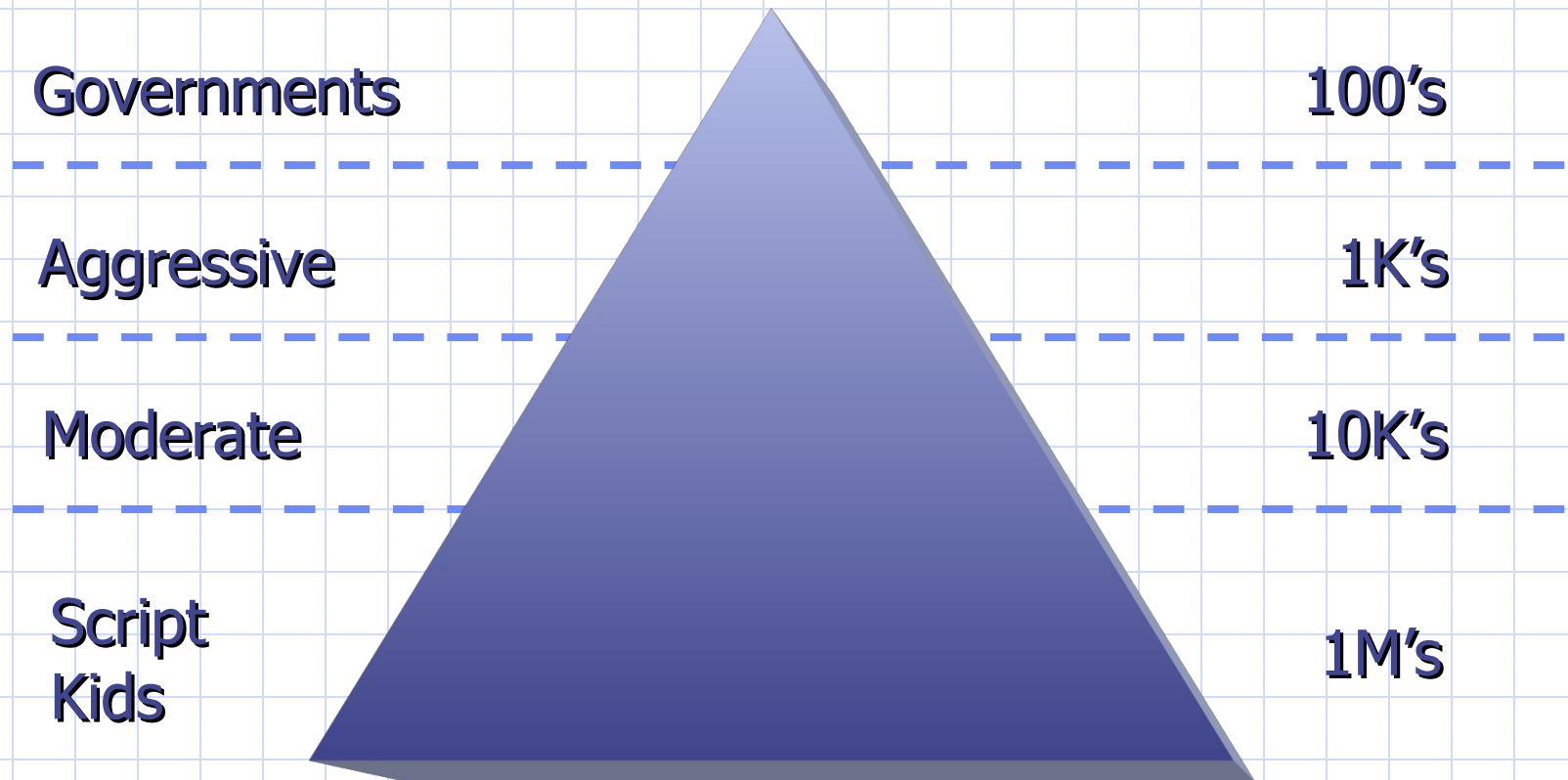
Source: CERT

Reported Vulnerabilities



Source: CERT

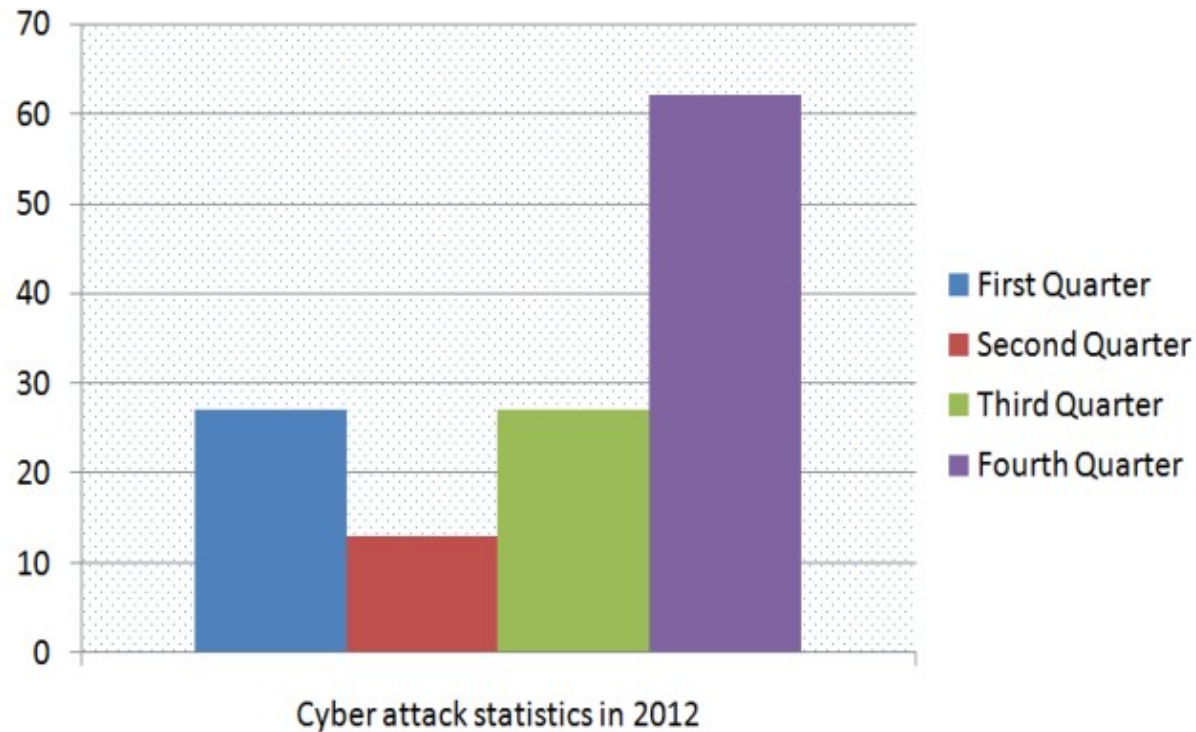
Threat Pyramid



Source: Tom Perrine, SDSC
Security as Infrastructure

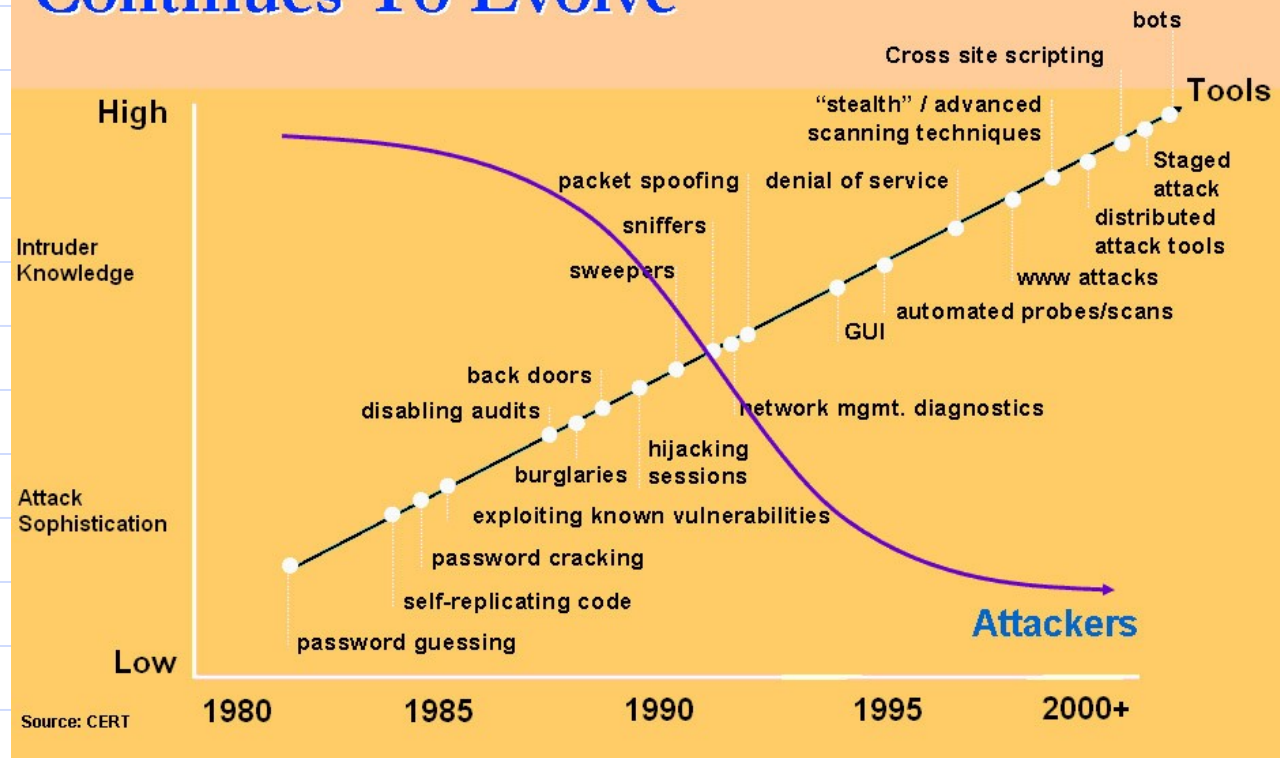
2012 Eth.C Cyber attack

Ethiopian Cyber Attack Statistics in 2012



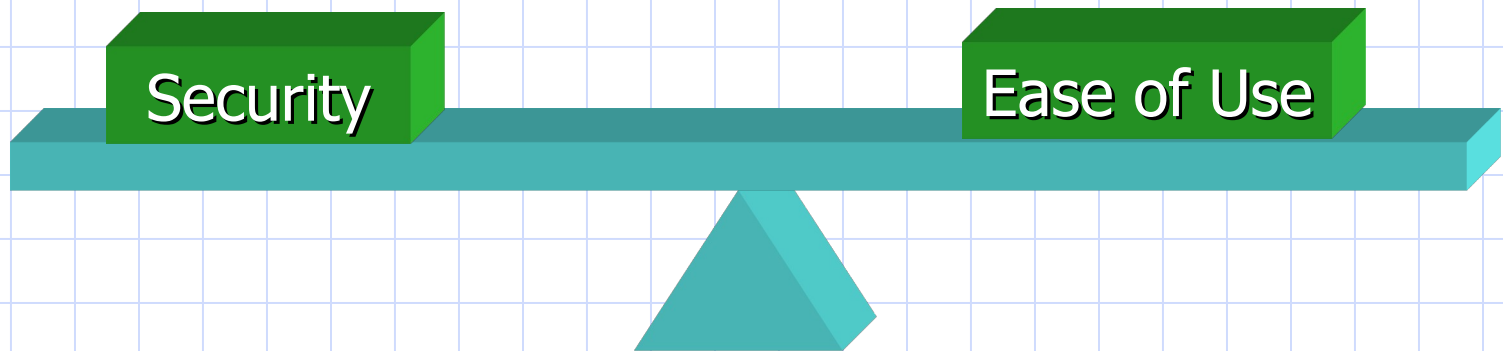
Treat Evolution

Cyber Attack Sophistication Continues To Evolve



Source: CERT (Phishing Exposed)

How much security?



Beware of Security through Obscurity!!!

Password Security Issues

◆ Low-tech password grabbing

- Social Engineering
- Dumpster Diving
- Shoulder Surfing

◆ Password Cracking

- Encrypted passwords accessible
- Brute force & dictionary attacks
 - ◆ Alec Muffett's Crack
 - ◆ John the Ripper
 - ◆ Cain and Able
 - ◆ Rainbow Cracking

Password Risk Minimization

- ◆ User Education!!!
- ◆ Password Accessibility (`/etc/shadow`)
- ◆ Allow for longer passwords
- ◆ One-Time Passwords – OPIE/SecurID
- ◆ Password aging
 - Forces periodic changing of password
 - Accounts locked if password expires
- ◆ Centralized Authentication
 - Kerberos
 - Active Directory Services (ADS)

/etc/shadow Fields

- ◆ Username
- ◆ Encrypted password
- ◆ Day last changed
- ◆ Minimum # days between changes
- ◆ Maximum # days between changes
- ◆ Notify # days before account expires
- ◆ Account Inactivation
 - Expire # days after max change (Linux)
 - Expire after # days of inactivity (Solaris)
- ◆ Expiration day
- ◆ Flags (unused)

Example: `sorr:1Yi8.KpsFAB9M:11262::90:7:12784:`

Account Management

- ◆ *Principle of least privilege*
- ◆ Restrictive default `umask`
- ◆ Disable/remove inactive accounts
- ◆ No shared group accounts
- ◆ Careful placement of `.' in PATH
- ◆ Same username/UID assignment on all systems on a local network

Root Account Management

- ◆ Restrict root logins to console
- ◆ Used only when needed
 - `su -`
 - `sudo`
- ◆ Avoid multiple root accounts (UID: 0)
- ◆ Avoid ``.`` in PATH
- ◆ Be Careful!!!

System Configuration

- ◆ Keep all software up to date
 - Updates
 - Patches
- ◆ Remove unneeded software
- ◆ Minimize SUID/SGID programs
- ◆ Kernel options
- ◆ System-wide defaults
- ◆ System Hardening
 - SELinux
 - CIS Benchmark Tools
 - Microsoft: Baseline Security Analyzer

Pluggable Auth. Modules

- ◆ System-wide authentication defaults
- ◆ Authentication management
- ◆ Account management
- ◆ Session management
- ◆ Password management

Filesystem Protection

◆ Check for...

- World-writable files/directories
- World-readable files/directories
 - ◆ System configuration files
 - ◆ Log files
- Ownerless files/directories
- SUID/SGID programs

◆ Filesystem access restrictions

◆ Trojan horses & root-kits

- Modified system files/programs
- Integrity Checkers: Tripwire, AIDE, Osiris

◆ Filesystem Encryption (CFS, EFS)

Network Service Security

- ◆ Remove unneeded services
 - RC Scripts
 - `inetd/xinetd`
- ◆ Upgrade/Patch active services
- ◆ Port Scanners – nmap, Saint, Nessus
- ◆ Service Attack Detection/Protection
 - Intrusion Detection Systems (Snort)
 - TCP Wrappers
 - Firewalls
 - Network Address Translation (NAT)

Network Traffic Issues

◆ Packet Sniffing

- See all traffic (passwords, email, etc.)
- Tools: Tcpdump, Wireshark

◆ Spoofing and Session Hijacking

◆ Network Session Encryption

- Telnet, ftp, X11: Secure Shell (ssh)
- Email, Web: Secure Socket Layer (SSL)
- Virtual Private Networks (IPSec/SSL)

Physical Security

◆ Environmental Concerns

◆ Facility Security

- Hardware cables
- Locks (Key, Code, Biometrics)
- Alarms (Theft, Movement, etc.)

◆ Removable media

◆ System BIOS

- Passwords
- Boot device order

◆ Boot Loader Passwords

Session Security

◆ X-Windows

- Remote Applications
- Remote viewing of your windows
- `xhost/xauth` access control

◆ Console locking

- GUI Screensavers
- Text console(s) – `vlock`

◆ Shell inactivity timeout

Implementing Security

- ◆ Risk Assessment
- ◆ Policy Development
- ◆ Implementation
- ◆ Testing
- ◆ Monitoring/Responding to Incidents

Risks and Policies

◆ Risk Assessment

- Identifying assets, vulnerabilities, threats
- Prevention Cost $\leftrightarrow$ Lost/Recovery Cost

◆ Policy Development

- “That which is not permitted is prohibited”
- Grant authority to enforce policy
- Periodic reviews
- Be positive

System Testing

◆ Password Checkers

◆ Vulnerability Checkers

- System: COPS, Titan, Tiger
- Network: Saint (SARA), Nessus, nmap

◆ Bug Exploits

- Script Kiddie sites (i.e. www.rootshell.com)
- Full Disclosure Email Lists (i.e. BugTraq)
- Security Advisories (i.e. CERT)

Log Monitoring

◆ Baseline Anomalies

- Weird su/root login entries
- Unscheduled Reboots/Service restarts
- Inconsistent login times/locations

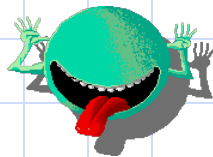
◆ Logfile Anomalies

- Strange timestamps
- Incorrect ownership or permissions
- Short, incomplete, or missing logs

◆ Centralized logging

Incident Response

- ◆ Isolate the system
- ◆ Understand what happened - Forensics
 - Active system analysis
 - Filesystem analysis (make read-only first)
- ◆ Recover
 - Close holes
 - Restore files from clean backup
- ◆ Report incident



Don't Panic!!!